Ethical Hacking

(230704201)

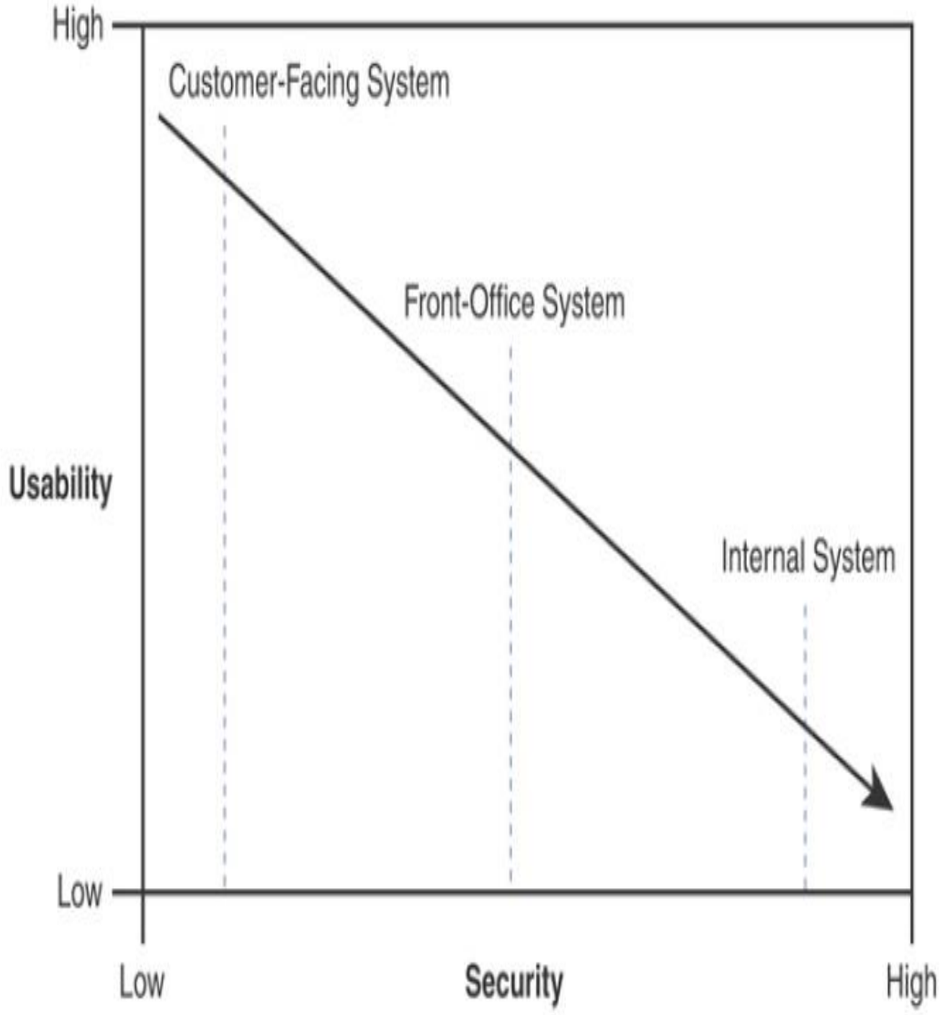
Unit 1: Introduction to Ethical Hacking, Foot printing & Scanning

Reference:

Michael Gregg, Omar Santos:- CEH Certified Ethical Hacker Cert Guide

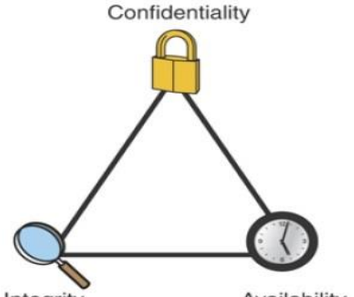
Security Fundamentals

- One way to secure a system from network attack is to unplug it and make it a standalone system.
- Although this system would be relatively secure from Internet-based attackers, its usability would be substantially reduced.
- The opposite approach of plugging it in directly to the Internet without any firewall, antivirus, or security patches would make it extremely vulnerable, yet highly accessible.
- So, here again, you see that the job of security professionals is to find a balance somewhere between security and usability.



Goals of Security

- Security can be achieved in many ways, but it's universally agreed that the security triad of confidentiality, integrity, and availability (CIA) forms the basic building blocks of any good security initiative.
- **Confidentiality** addresses the secrecy and privacy of information. Physical examples of confidentiality include locked doors, armed guards, and fences. In the logical world, confidentiality must protect data in storage and in transit.
- **Integrity** is the second piece of the CIA security triad. Integrity provides for the correctness of information.
- It allows users of information to have confidence in its correctness. Correctness doesn't mean that the data is accurate, just that it hasn't been modified in storage or transit.



The CIA Triad

- Integrity can apply to paper or electronic documents. It is much easier to verify the integrity of a paper document than an electronic one.
- Integrity in electronic documents and data is much more difficult to protect than in paper ones.
- Integrity must be protected in two modes: storage and transit.
- Information in storage can be protected if you use access and audit controls. Cryptography can protect information in storage through the use of hashing algorithms and digital signatures.
- Integrity in transit can be ensured primarily by the use of standards to transport the data. These protocols use hashing and cryptography to provide security controls.

GLS FCAIT MCA

- **Availability** means that when a legitimate user needs the information, it should be available. access to a backup facility 24/7 does not help if there are no updated backups from which to restore.
- Similarly, cloud storage is of no use if the cloud provider or network connections are down.
- Fault tolerant systems can be used to ensure availability, and backups are another way. Backups provide a copy of information should files and data be destroyed or otherwise be made unavailable because of equipment failure.
- Denial of service (DoS) is an attack against availability.

GLS FCAIT MCA

- To be a security professional, you need to understand the relationship between risk, threats, assets, and vulnerabilities.
- Risk is the probability or likelihood of the occurrence or realization (understanding) of a threat.
- An asset is any item of economic value owned by an individual or corporation. Assets can be real—such as routers, servers, hard drives, and laptops—or virtual, such as formulas, databases, spreadsheets, trade secrets, and processing time.
- A threat sets the stage for risk and is any agent, condition, or circumstance that could potentially cause harm, loss, or damage, or compromise an IT asset or data asset.

✓ Threats can be categorized as events that can affect the confidentiality, integrity, or availability of the organization's assets.

✓These threats can result in destruction, disclosure, modification, corruption of data, or denial of service.

GLS FCAIT MCA

✓ Examples of the types of threats an organization can face include the following:

1. Natural disasters, weather, and catastrophic damage:- Hurricanes, storms, weather outages, fire, flood, earthquakes, and other natural events that compose an ongoing threat.
2. Hacker attacks: An insider or outsider who is unauthorized and purposely attacks an organization's infrastructure, components, systems, or data.
3. Cyberattack: Attackers who target critical national infrastructures such as water plants, electric plants, gas plants, oil refineries, gasoline refineries, nuclear power plants, waste management plants, and so on.
4. Viruses and malware: An entire category of software tools that are malicious and are designed to damage or destroy a system or data. The Conti ransomware that uses a file less malware attack is one example of malware.
5. Disclosure of confidential information: Anytime a disclosure of confidential information occurs, it can be a critical threat to an organization if that disclosure causes loss of revenue, causes potential liabilities, or provides a competitive advantage to an adversary.

GLS FCAIT MCA

6. Denial-of-Service (DoS) or Distributed DoS (DDoS) attacks: An attack against availability that is designed to bring the network or access to a particular TCP/IP host/server to its knees by flooding it with useless traffic.

✓ Today, most DoS attacks are launched via botnets, whereas in the past, tools such as the Low Orbit Ion Cannon or High Orbit Ion Cannon may have been used.

➢ A vulnerability (susceptibility /weakness) is a weakness in the system design, implementation, software, or code, or the lack of a mechanism.

✓A specific vulnerability might manifest (obvious) as anything from a weakness in system design to the implementation of an operational procedure.

✓Vulnerabilities might be eliminated or reduced by the correct implementation of safeguards and security countermeasures.

✓ Vulnerabilities and weaknesses are common, mainly because there isn't any perfect software or code in existence.

✓ Vulnerabilities can be found in each of the following:

1. Applications: Software and applications come with tons (loads) of functionality. Applications may be configured for usability rather than for security. Applications may be in need of a patch or update that may or may not be available.

✓ Even if the application itself might not have a vulnerability, there might be a vulnerability in the third party components the application uses

2. Operating systems: System software that is loaded in workstations and servers. Attacks can search for vulnerabilities in operating systems that have not been patched or updated.

3. Misconfiguration: The configuration file and configuration setup for the device or software may be misconfigured or may be deployed in an unsecure state. This might be open ports, vulnerable services, or misconfigured network devices.

4. Shrink-wrap software: The application or executable file that is run on a workstation or server. When installed on a device, it can have tons (loads) of functionality or sample scripts or code available.

GLS FCAIT MCA

Backing Up Data to Reduce Risk:-

- One way to reduce risk is by backing up data. Although backups won't prevent problems such as ransomware, they can help mitigate the threat.
- The method your organization chooses depends on several factors:

1. Full backups: During a full backup, all data is backed up, and no files are skipped or bypassed; you simply designate which server to back up. A full backup takes the longest to perform and the least time to restore when compared to differential or incremental backups, because only one set of tapes is required.

2. Differential backups: Using differential backup, a full backup is typically done once a week, and a daily backup is completed that copies all files that have changed since the last full backup. If you need to restore, you need the last full backup and the most recent differential backup.

GLS FCAIT MCA

3. Incremental backups: This backup method works by means of a full backup scheduled for once a week, and only files that have changed since the previous full backup or previous incremental backup are backed up each day.

✓ This is the fastest backup option, but it takes the longest to restore. Incremental backups are unlike differential backups.

✓ When files are copied, the archive bit is reset; therefore, incremental backups back up only changes made since the last incremental backup.

GLS FCAIT MCA

Defining an Exploit:-

- An exploit (abuse) refers to a piece of software, a tool, a technique, or a process that takes advantage of a vulnerability that leads to access, privilege escalation (growth), loss of integrity, or denial of service on a computer system.
- Exploits are dangerous because all software has vulnerabilities; hackers and perpetrators (culprits) know that there are vulnerabilities and seek to take advantage of them.
- Although most organizations attempt to find and fix vulnerabilities, some organizations lack sufficient funds for securing their networks. Sometimes no one may even know the vulnerability exists, and it is exploited. That is known as a zero-day exploit.
- Even when you do know there is a problem, you are burdened with the fact that a window exists between when a vulnerability is disclosed and when a patch is available to prevent the exploit.
- The more critical the server, the slower it is usually patched.

GLS FCAIT MCA

Risk Assessment:- A risk assessment is a process to identify potential security hazards (dangers) and evaluate what would happen if a hazard or unwanted event were to occur.

- There are two approaches to risk assessment: qualitative and quantitative.
- Qualitative risk assessment methods use scenarios to drive a prioritized list of critical concerns and do not focus on dollar amounts. Example impacts might be identified as critical, high, medium, or low.
- Quantitative risk assessment assigns a monetary value to the asset. It then uses the anticipated (expected) exposure to calculate a dollar cost.
- The steps are as follows:

1. Step 1: Determine the Single Loss Expectancy (SLE): This step involves determining the single amount of loss you could incur (sustain) on an asset if a threat becomes realized or exposed to the threat one time.

✓ SLE is calculated as follows: SLE = asset value (AV) × exposure factor (EF). The exposure factor (EF) is the subjective, potential portion of the loss to a specific asset if a specific threat were to occur.

GLS FCAIT MCA

2. Step 2: Evaluate the Annual Rate of Occurrence(ARO):-

- ✓ The purpose of evaluating the ARO is to determine how often an unwanted event is likely to occur on an annualized basis.

3. Step 3.Calculate the Annualized Loss Expectancy (ALE):

- ✓ This final step of the quantitative assessment seeks to combine the potential loss and rate per year to determine the magnitude of the risk.
- ✓ This is expressed as annualized loss expectancy (ALE), which is calculated as follows: ALE = SLE × ARO.

GLS FCAIT MCA

- CEH exam questions might ask you to use the SLE and ALE risk formulas. For example, a question might ask, “

Question:- If you have data worth $500 that has an exposure factor of 50 percent due to lack of countermeasures such as EDR(Enhanced Data Rate) what would the ALE be?” As part of a follow-up test question, could you calculate the annualized loss expectancy (ALE) if you knew that this type of event typically happened 4(four) times a year?

Solution:- You would use the following formula to calculate the answer:

SLE × ARO = ALE, or $500 × .50 = $250

- Yes, as this would mean the ARO is 4. Therefore:

ALE = SLE × ARO or $250 × 4 = $1,000

This means that, on average, the loss is $1,000 per year.

GLS FCAIT MCA

Security Testing

- Security testing is the primary job of ethical hackers. These tests might be configured in such a way that the ethical hackers have no knowledge, full knowledge, or partial knowledge of the target of evaluation (TOE).

- **No-Knowledge Tests (Black Box):-**

✓ No-knowledge testing is also known as black box testing.

✓ Simply stated, the security team has no knowledge of the target network or its systems.

✓ Black box testing simulates an outsider attack, because outsiders usually don't know anything about the network or systems they are probing.

✓ The attacker must gather all types of information about the target to begin to profile its strengths and weaknesses.

GLS FCAIT MCA

GLS UNIVERSITY
Promoted By Gujarat Law Society Since 1927

➢The advantages of black box testing include the following:

✓ The test is unbiased because the designer and the tester are independent of each other.

✓ The tester has no prior knowledge of the network or target being examined. Therefore, there are no preconceptions about the function of the network.

✓ A wide range of investigation work is usually done to footprint the organization, which can help identify information leakage.

✓ The test examines the target in much the same way as an external attacker.

GLS FCAIT MCA

➢ The disadvantages of black box testing include the following:

✓ Performing the security tests can take more time than partial- or full-knowledge testing.

✓It is usually more expensive because it takes more time to perform.

✓ It focuses only on what external attackers see, whereas in reality many attacks are launched by insiders.

➢ Full-Knowledge Testing (White Box):-

✓ White box testing takes the opposite approach of black box testing.

✓This form of security test takes the premise that the security tester has full knowledge of the network, systems, and infrastructure.

✓This information allows the security tester to follow a more structured approach and not only review the information that has been provided but also verify its accuracy.

✓So, although black box testing will usually spend more time gathering information, white box testing will spend that time probing for vulnerabilities.

GLS FCAIT MCA

➢ Partial-Knowledge Testing (Gray Box):-

✓ In the world of software testing, gray box testing is described as a partial-knowledge test. EC-Council literature describes gray box testing as a form of internal test.

✓ Therefore, the goal is to determine what insiders can access. This form of test might also prove useful to the organization because so many attacks are launched by insiders.

GLS FCAIT MCA

Cyber Kill Chain

- There are several specialized incident response methodologies available, such as the MITRE ATT&CK six stage framework and the Lockheed Martin seven-stage cyber kill chain framework.
- Both of these methodologies describe the structure and lifecycle of a cyberattack.
- The goal of the cyber kill chain is to track the stages of the cyberattack from reconnaissance (investigation) to data exfiltration. These steps include:

1. Step 1: Reconnaissance (Survey): Active and passive information gathering
2. Step 2: Intrusion: Gaining access
3. Step 3: Exploitation: Taking control of a system, service, or application
4. Step 4: Privilege escalation: Gaining elevated access.
5. Step 5: Lateral movement: Moving from system to system to expand access.
6. Step 6: Obfuscation: Hiding or covering your tracks.
7. Step 7: Denial of service: Preventing legitimate access by flooding or overwhelming the service.
8. Step 8: Exfiltration: Unauthorized data transfer by the threat actor

G L S F C A I T M C A

Hacker and Cracker Descriptions

- The term hacker was used for a computer enthusiast.
- A hacker was a person who enjoyed understanding the internal workings of a system, computer, and computer network and who would continue to hack until he understood everything about the system.
- The hackers as individuals who broke into computers with malicious intent.
- The industry responded by developing the word cracker, which is short for a criminal hacker.
- The term cracker was developed to describe individuals who seek to compromise the security of a system without permission from an authorized party.
- An ethical hacker is an individual who performs security tests and other vulnerability-assessment activities to help organizations secure their infrastructures. Sometimes ethical hackers are referred to as white hat hackers.

GLS FCAIT MCA

- Let's look at some common categories:

1. White hat hackers: These individuals perform ethical hacking to help secure companies and organizations. Their belief is that you must examine your network in the same manner as a criminal hacker to better understand its vulnerabilities.
2. Black hat hackers: These individuals perform illegal activities, such as organized crime.
3. Gray hat hackers: These individuals usually follow the law but sometimes risk over to the darker side of black hat hacking. It would be unethical to employ these individuals to perform security duties for your organization because you are never quite clear where they stand.
4. Suicide hackers: These are individuals who may carry out an attack even if they know there is a high chance that they will get caught and serve a long prison term.

GLS FCAIT MCA

GLS UNIVERSITY
Promoted By Gujarat Law Society Since 1927

- Hackers usually follow a fixed methodology that includes the following steps:

1. Reconnaissance and foot printing: This step can be both passive and active.
2. Scanning and enumeration: This step can include the use of port scanning tools and network mappers.
3. Gaining access: This step encompasses locating the entry point into the network, application, or system.
4. Moving laterally: This step involves moving from system to system to expand access.
5. Maintaining access: This step employs techniques used to maintain control, such as escalation of privilege.
6. Covering tracks: Planting rootkits or backdoors, clearing logs, and even running ransomware are activities normally performed at this step.

GLS FCAIT MCA

Who Attackers Are:-

- Ethical hackers are up against several types of individuals in the battle to secure the network. There are a lot of misperceptions (confusions) about what a hacker is.

1. Phreakers: The original hackers. These individuals hacked telecommunication and PBX systems to explore the capabilities and make free phone calls.
2. Script kiddies: A term used to describe often younger (fresher) attackers who use widely available freeware vulnerability-assessment tools and hacking tools that are designed for attacking purposes only.

- These attackers usually do not have programming or hacking skills and, given the techniques used by most of these tools, can be defended against with the proper security controls and risk-mitigation strategies.

3. Disgruntled (Unhappy) employees: Employees who have lost respect and integrity for the employer. These individuals might or might not have more skills than the script kiddie.

GLS FCAIT MCA

3. Software crackers/hackers: Individuals who have skills in reverse engineering software programs and, in particular, licensing registration keys used by software vendors when installing software onto workstations or servers. Although many individuals are eager to contribute of their services, anyone who downloads programs with cracked registration keys is breaking the law. These items can be a potential risk and might have malicious code and malicious software threats injected into the code.
4. Cyberterrorists/cybercriminals: An increasing category of threat that can be used to describe individuals or groups of individuals who are usually funded to conduct clandestine (secret) or espionage (spying) activities on governments, corporations, and individuals in an unlawful manner.

- These individuals are typically engaged in sponsored acts of damage: DoS/DDoS attacks, identity theft, financial theft, or worse, compromising critical infrastructures in countries, such as nuclear power plants, electric plants, water plants, and so on.

GLS FCAIT MCA

5. System crackers/hackers: Elite hackers who have specific expertise in attacking vulnerabilities of systems and networks by targeting operating systems.

- These individuals get the most attention and media coverage because of the globally affected malware, botnets, and Trojans that are created by system crackers/hackers.
- System crackers/hackers perform interactive probing activities to exploit security defects and security flaws in network operating systems and protocols.

GLS FCAIT MCA

Ethical Hackers

- Ethical hackers perform penetration (saturation) tests. They perform the same activities hackers would but without malicious intent (resolved).
- They must work closely with the host organization to understand what the organization is trying to protect, who they are trying to protect these assets from, and how much money and resources the organization is willing to expend to protect the assets.
- Similar to that of an attacker, ethical hackers seek to see what type of public information is available about the organization. Information leakage can reveal critical details about an organization, such as its structure, assets, and defensive mechanisms.
- After the ethical hacker gathers this information, it is evaluated to determine whether it poses any potential (possible) risk. The ethical hacker further probes(investigated), the network at this point to test for any unseen weaknesses

GLS FCAIT MCA

Required Skills of an Ethical Hacker

- Ethical hackers need hands-on security skills. Although you do not have to be an expert in everything, you should have an area of expertise. These skills include the following:

1. Routers: Knowledge of routers, routing protocols, and Access Control Lists (ACLs). Certifications such as Cisco Certified Network Associate (CCNA) and Cisco Certified Internetworking Expert (CCIE) can be helpful.
2. Microsoft: Skills in the operation, configuration, and management of Microsoft-based systems. These can run the scope from Windows 10 to Windows Server 2019. These individuals might be Microsoft Certified Solutions Associate (MCSA) or Microsoft Certified Solutions Expert (MCSE) certified.
3. Linux: A good understanding of the Linux/UNIX OS. This includes security settings, configuration, and services such as Apache. These individuals may be Fedora or Linux+ certified.

GLS FCAIT MCA

Required Skills of an Ethical Hacker

4. MacOS: A good understanding of Apple systems (laptops, iPads, and smartphones), which are a big part of today's computing environment.
5. Firewalls: Knowledge of firewall configuration and the operation of Intrusion Detection Systems (IDS) and Intrusion Prevention Systems (IPS) can be helpful when performing a security test. Individuals with these skills may be certified as a Cisco Certified Network Associate Security Professional (CCNA) or Check Point Certified Security Administrator (CCSA).
6. Programming: Knowledge of programming, including SQL; programming languages such as C++, Ruby, C#, and C; and scripting languages such as PHP and Java.
7. Mainframes: Although mainframes do not hold the position of dominance they once had in business, they still are widely used. If the organization being assessed has mainframes, the security teams would benefit from having someone with that skill set on the team.

GLS FCAIT MCA

Required Skills of an Ethical Hacker

8. Network protocols: Most modern networks are Transmission Control Protocol/Internet Protocol (TCP/IP). Someone with good knowledge of networking protocols, as well as how these protocols function and can be manipulated, can play a key role in the team. These individuals may possess certifications in other operating systems or hardware or may even possess a CompTIA Network+, Security+, or Advanced Security Practitioner (CASP) certification.
9. Project management: Someone will have to lead the security test team, and if you are chosen to be that person, you will need a variety of the skills and knowledge types listed previously. It can also be helpful to have good project management skills. The parameters of a project are typically time, scope, and cost. After all, you will be defining the project scope when leading a penetration test team. Individuals in this role may benefit from having Project Management Professional (PMP) certification.

GLS FCAIT MCA

Modes of Ethical Hacking

- The ethical hacker can put these skills to use an organization's IT infrastructure can be probed (investigated), analysed, and attacked in a variety of ways. Some of the most common modes of ethical hacking.

1. Information gathering: This testing technique seeks to see what type of information is leaked by the company and how an attack might leverage (control) this information.
2. External penetration testing: This ethical hack seeks to simulate the types of attacks that could be launched across the Internet. It could target Hypertext Transfer Protocol (HTTP), Simple Mail Transfer Protocol (SMTP), Structured Query Language (SQL), or any other available service.
3. Internal penetration testing: This ethical hack simulates the types of attacks and activities that could be carried out by an authorized individual with a legitimate connection to the organization's network.

GLS FCAIT MCA

Modes of Ethical Hacking

4. Network gear testing: This technique involves the firewall, IDS, routers, and switches.
5. DoS testing: This testing technique can be used to stress test systems or to verify their ability to withstand a DoS attack.
6. Wireless network testing: This testing technique looks at wireless systems. This might include wireless networking systems, RFID, ZigBee, Bluetooth, or any wireless device.
7. Application testing: Application testing is designed to examine input controls and how data is processed. All areas of the application may be examined.
8. Social engineering: Social engineering attacks target the organization's employees and manipulate them to gain privileged information. Employee training, proper controls, policies, and procedures can go a long way in defeating this form of attack.

GLS FCAIT MCA

Modes of Ethical Hacking

9. Physical security testing: This simulation seeks to test the organization's physical controls. Systems such as doors, gates, locks, guards, closed circuit television (CCTV), and alarms are tested to see whether they can be bypassed.
10. Authentication system testing: This simulated attack is tasked with assessing authentication controls. If the controls can be bypassed, the ethical hacker might probe to see what level of system control can be obtained.
11. Database testing: This testing technique is targeted toward SQL servers.
12. Communication system testing: This testing technique examines communications such as PBX, Voice over IP (VoIP), modems, and voice communication systems.
13. Stolen equipment attack: This simulation is closely related to a physical attack because it targets the organization's equipment. It could seek to target the CEO's laptop or the organization's backup tapes. No matter what the target, the goal is the same: extract critical information, usernames, and passwords.

GLS FCAIT MCA

Test Plans—Keeping It Legal

- Make plans before, an ethical hacking test can begin, the scope of the engagement must be determined. Defining the scope of the assessment is one of the most important parts of the ethical hacking process.
- Companies can decide to perform these tests for various reasons. The most common reasons include the following:

1. A breach in security: One or more events have occurred that highlight a lapse in security. It could be that an insider was able to access data that should have been unavailable, or it could be that an outsider was able to hack the organization's web server.

2. Due diligence: Due diligence (carefulness) is another reason a company might decide to perform a pen test. The pen test might occur before the purchase or after the event. These assessments are usually held to a strict timeline. There is only a limited amount of time before the purchase, and if the assessments are performed afterward.

GLS FCAIT MCA

Test Phases

- Security assessments in which ethical hacking activities will take place are composed of three phases:
- scoping the project, in which goals and guidelines are established;
- performing the assessment; and performing post-assessment activities, including the report and remediation activities.
- Figure 1-4 shows the three phases of the assessment and their typical times.

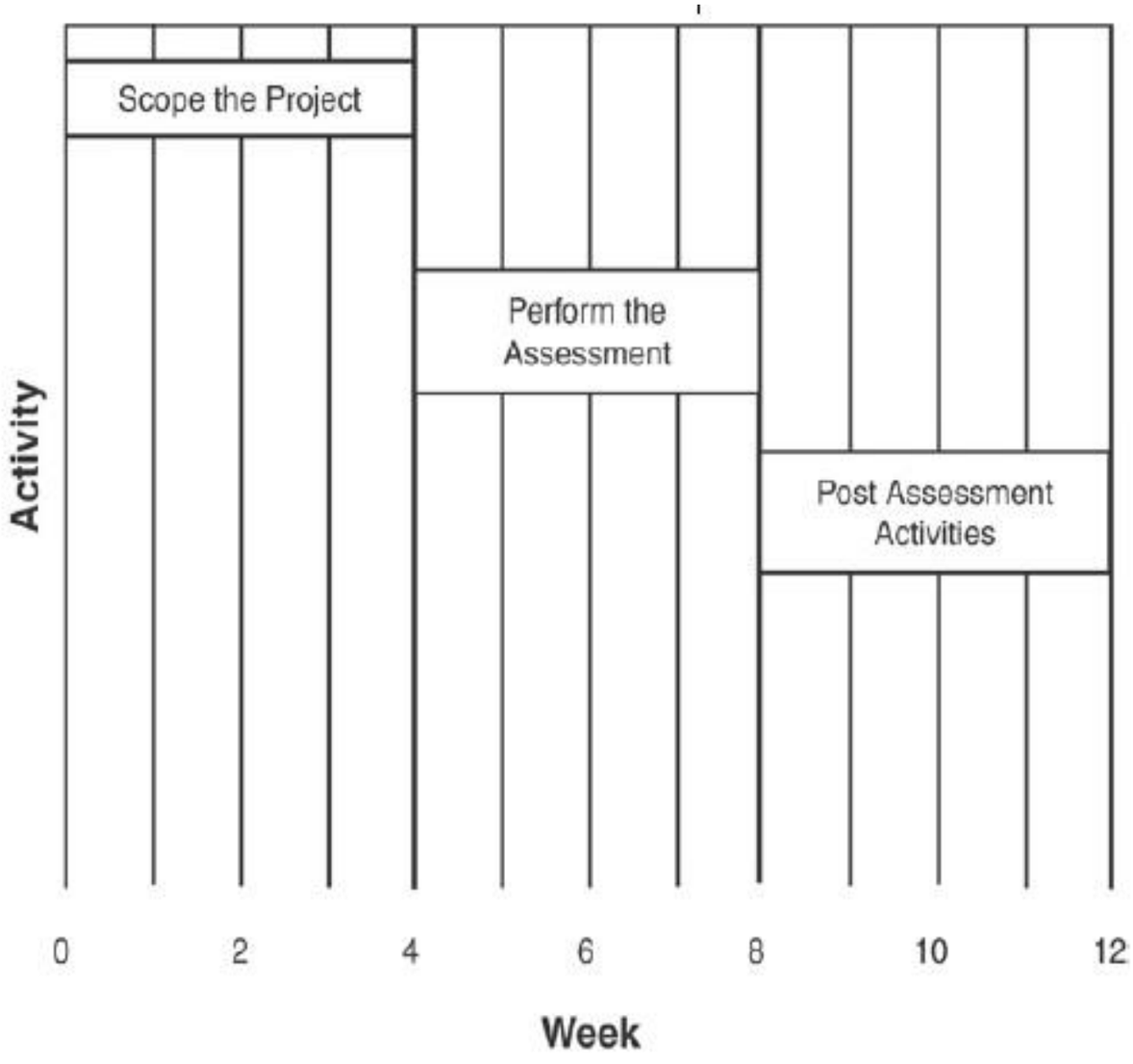


Figure 1-4 Ethical Hacking Phases and Times

Establishing Goals

- The need to establish goals is critical. Common goals include system certification and accreditation, verification of policy compliance (agreement), and proof that the IT infrastructure has the capability to defend against technical attacks.
- Certification is a technical evaluation of the system that can be carried out by independent security teams or by the existing staff. Its goal is to uncover any vulnerabilities or weaknesses in the implementation.
- The goal will be to test these systems to make sure that they are configured and operating as expected, that they are connected to and communicate with other systems in a secure and controlled manner, and that they handle data in a secure and approved manner.

GLS FCAIT MCA

Establishing Goals

- The security team will be looking at the controls implemented to protect information being stored, being transmitted, or being processed.
- This type of security test might not have as much hands-on hacking but might use more social engineering techniques and testing of physical controls.
- The goal of a technical attack might be to see what an insider or outsider can access. Your goal might be to gather information as an outsider and then use that data to launch an attack against a web server or externally accessible system.

GLS FCAIT MCA

Ethical Hacking Report

- You have not actually begun testing, you do need to start thinking about the final report. There shouldn't be any big surprises when you submit the report.
- Although you might have found some serious problems, they should be discussed with management before the report is written and submitted.
- The report itself should detail the results of what was found. It should present the results of the assessment in an easily understandable and fully traceable way.
- The report should be comprehensive (complete) and self-contained.
- Most reports contain the following sections:

1. Introduction,
2. Statement of work performed Results and
3. conclusions
4. Recommendations

GLS FCAIT MCA

Vulnerability Research and Bug Bounties—Keeping Up with Changes

- If you are moving into the IT security field or are already working in IT security, you probably already know how quickly things change in this industry. That pace of change requires the security professional to keep abreast (up-to-date) of new/developing tools, techniques, and emerging vulnerabilities.
- Security in the 2010s might know about Stuxnet or the Sasser Worm, that will do little good to combat (fight) ransomware or a Hafnium Exchange Server attack. Because tools become obsolete and exploits become out-dated, you want to build up a list of websites that you can use to keep up with current vulnerabilities.
- The sites listed here are but a few you should review:
- National Vulnerability Database: https://nvd.nist.gov/
- Security Tracker: https://securitytracker.com/ Hacker Watch: https://www.hackerwatch.org/
- Dark Reading: https://www.darkreading.com/ Exploit Database: https://www.exploit-db.com/
- Hacker Storm: https://hackerstorm.co.uk/
- SANS Reading Room: https://www.sans.org/reading_room/
- SecurityFocus: https://www.securityfocus.com/

GLS FCAIT MCA

Task to the Students

➢ Searching for Exposed Passwords

1. Go to the Have I Been Pwned website located at https://haveibeenpwned.com/.
2. Enter your email address and check to see if any of your email accounts have been compromised.
3. Were any of your accounts compromised? If so, how many?
4. Verify that any passwords used at compromised sites are not being used at any other locations. If those passwords are in use elsewhere, you have left an easy way for a script kiddie to access your account.

GLS FCAIT MCA

➢What does pwned mean in cyber security?

PWN is hacker jargon (nonsense) meaning to conquer (overcome) or dominate. In the context of online security, pwned often means that your account or system has been breached, and your passwords—user passwords or privileged passwords—have been compromised.

Footprinting

- Footprinting is the first step of the hacking methodology, and it is all about gathering information. Most organizations share a tremendous amount of information and data through various channels, including their websites and social media pages, their employees, and even their help desks.
- Footprinting is about information gathering and is both passive and active. Reviewing the company's website is an example of passive footprinting, whereas the act of calling the help desk and attempting to social engineer them out of privileged information is an example of active information gathering.
- Port scanning entails (involves) determining network ranges and looking for open ports on individual systems.
- The EC-Council divides footprinting and scanning into seven basic steps, as illustrated in Figure 3-1.



Figure 3-1 Footprinting and Scanning Steps

Footprinting Methodology

- The information-gathering steps of footprinting and scanning are of utmost importance. Reconnaissance (Investigation) can be active or passive.
- Active means that you (the pen tester or ethical hacker) are using tools such as scanners to gather information about your targeted system.
- In other words, you are "actively" sending IP packets and interacting with the targeted system or network.
- In passive reconnaissance (Investigation) , you do not send any IP packets or interact with your target, but instead leverage (control) publicly available information. This information is also known as Open Source Intelligence (OSINT).

GLS FCAIT MCA

Documentation

- One important aspect of information gathering is documentation. The best way to get off to a good start is to develop a systematic method to profile a target and record the results.
- Create a matrix with fields to record domain name, IP address, DNS servers, employee information, email addresses, IP address range, open ports, and banner details.
- Figure 3-2 gives an example of what your information matrix might look like when you start the documentation process.

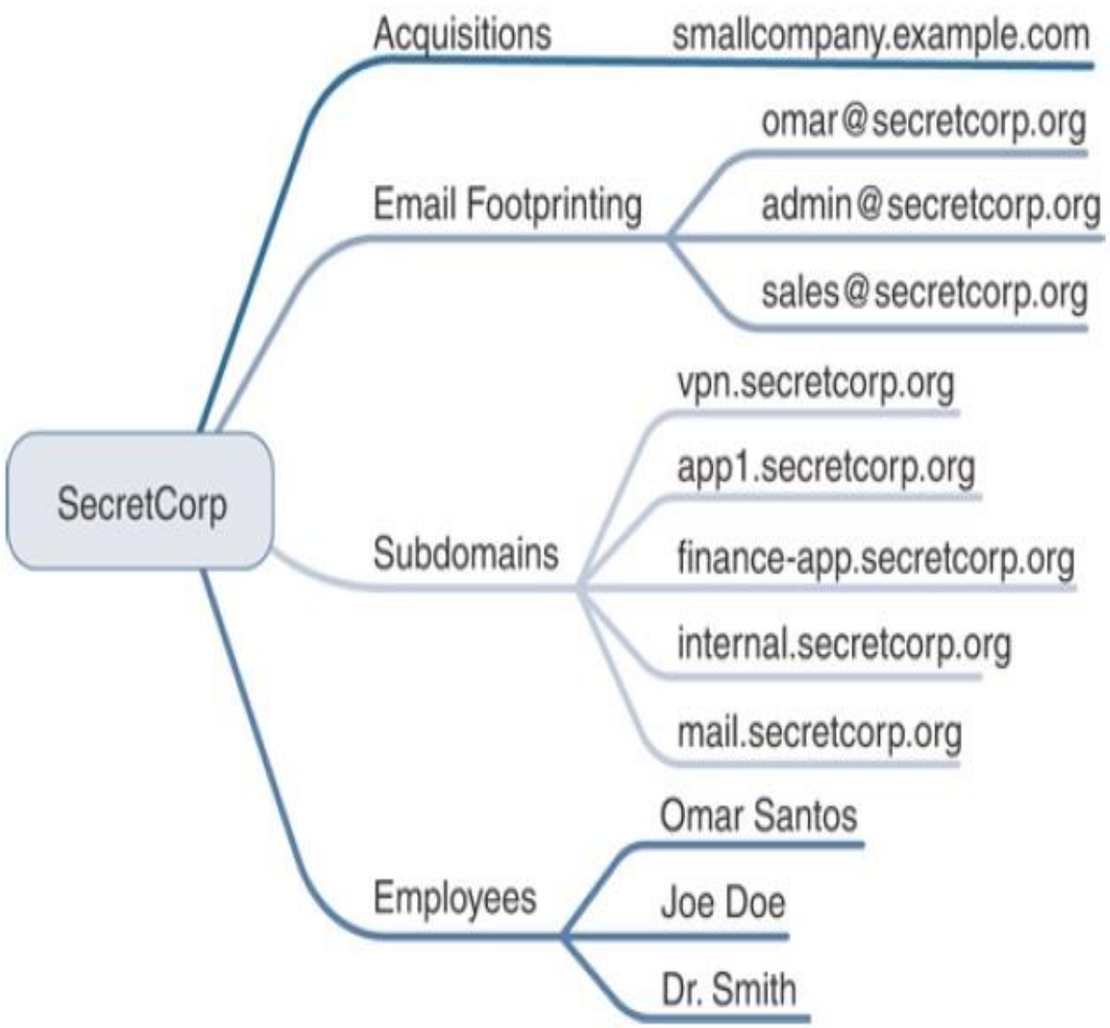


Figure 3-2 Documentation Finding

Footprinting Through Search Engines

- Most people use Google, DuckDuckGo, or other search engines to locate information on the Internet.
- What you might not know is that search engines, such as Google, can perform much more powerful searches than most people ever dream of.
- Not only can Google translate documents, perform news searches, and do image searches, but it also can be used by hackers and attackers to do something that has been termed Google hacking.
- Through the use of basic search techniques combined with advanced operators, Google can become a powerful vulnerability search tool.

GLS FCAIT MCA

Footprinting Through Social Networking Sites

- Social networks are another big target for attackers. Although social media has opened up great channels for communication and is very useful for marketers, it is fraught with potential security problems.

- Social networking sites are becoming one of the biggest threats to a user's security and will remain so for the foreseeable (predictable) future. One reason is that users don't always think about security when using these sites. There is also the issue that these sites are designed to connect people. Security is not always the primary concern.

- Some sites that you, as an ethical hacker, might want to check include the following:
- Facebook
- Twitter
- LinkedIn
- TikTok
- Pinterest

GLS FCAIT MCA

Footprinting Through Web Services and Websites

- One of the best places to begin footprinting is an organization's website. Search for the company's URL with Google, Bing, Dogpile, Shodan, or your search engine of choice. You will want to look for the following:

- Company URL: Domain name.
- Internal URLs: As an example, not only secretcorp.org but also internal.secretcorp.org, mail.secretcorp.org, finance-app.secretcorp.org, etc.
- Restricted URLs: Any domains not accessible to the public.
- Internal pages: Company news, employment opportunities, addresses, and phone numbers. Overall, you want to look for all open source information, which is information freely provided to clients, customers, or the general public.

GLS FCAIT MCA

Email Footprinting

- An ethical hacker is also going to want to see what information is available about key personnel. Whereas websites, employee directories, and press releases may provide employee names, third-party sites have the potential to provide sensitive data an attacker might be able to leverage.
- A staggering number of data aggregation brokerage sites are on the web. It is easy for an attacker to perform online searches about a person. These sites allow attackers to locate key individuals, identify home phone numbers, and even create maps to people's houses. Attackers can even see the surroundings of the company or the home they are targeting with great quality satellite pictures. Here are some of the sites:
- Pipl: https://pipl.com
- Spokeo: https://www.spokeo.com
- Whitepages: https://www.whitepages.com
- People Search Now: https://www.peoplesearchnow.com
- Zabasearch: https://www.zabasearch.com
- Peoplefinders: https://www.peoplefinders.com
- OSINT Framework: https://osintframework.com

GLS FCAIT MCA

Whois Footprinting

- Whois is a utility that interrogates (cross-examines) the Internet domain name administration system and returns the domain ownership, address, location, phone number, and other details about a specified domain name.
- Whois is the primary tool used to query Domain Name System (DNS). If you're performing this information gathering from a Linux computer, the good news is that Whois is built in. From the Linux prompt, you can type whois domainname.com or whois? to get a list of various options.
- Windows users are not as fortunate because Windows does not have a built-in Whois client. If you use Windows, you have to use a third party tool or website to obtain Whois information.
- One tool that a Windows user can use to perform Whois lookups is SmartWhois. You can download it from http://www.tamos.com/products/smartwhois/
- SmartWhois is a useful network information utility that allows you to look up all the available information about an IP address, hostname, or domain, including country, state or province, city, name of the network provider, administrator, and technical support contact information.

GLS FCAIT MCA

DNS(Domain Name Server) Footprinting

- The DNS might be targeted for zone transfers.
- A zone transfer is the mechanism used by DNS servers to update each other by transferring the contents of their database.
- DNS is structured as a hierarchy so that when you request DNS information, your request is passed up the hierarchy until a DNS server is found that can resolve the domain name request.

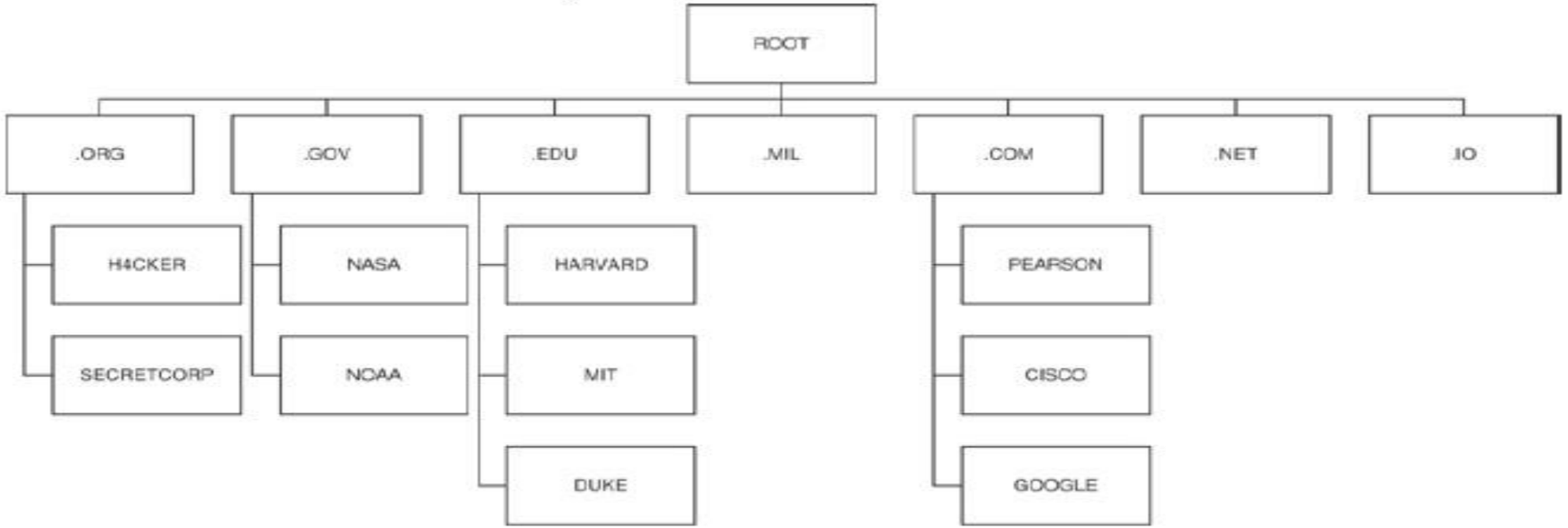


Figure 3-7 DNS Structure

DNS(Domain Name Server) Footprinting

- The primary tool to query DNS servers is Nslookup. Nslookup provides machine name and address information. Both Linux and Windows have Nslookup clients. You use Nslookup by typing nslookup at the command line followed by an IP address or a machine name.
- Type in, command prompt,

  nslookup google.com nslookup www.glsuniversity.ac.in

  nslookup h4cker.org dig h4cker.org
- There is also a range of tools that can be used to interrogate DNS servers, including the following:
- DomainDossier: https://centralops.net/co/domaindossier.aspx
- ViewDNS: https://viewdns.info
- MassDNS: https://github.com/blechschmidt/massdns
- Domain to IP Converter: https://domaintoipconverter.com
- DNSMap: https://code.google.com/archive/p/dnsmap/

GLS FCAIT MCA

Network Footprinting

- The pen test team has been able to locate names, phone numbers, addresses, some server names, and IP addresses, it's important to find out what IP addresses are available for scanning and further enumeration. If you take the IP address of a web server discovered earlier and enter it into the Whois lookup at https://www.arin.net, you can determine the network's range.
- type in cmd , tracert www.google.com

  tracert www.glsuniversity.ac.in

GLS FCAIT MCA

- The Graphical User Interface (GUI) program to perform traceroute with

1. LoriotPro
2. Trout
3. VisualRoute

Footprinting Through Social Engineering

- An attacker can also reveal a lot of information about the targeted organization and underlying systems by using social engineering. The reason is that, in many cases, it is even easier to get sensitive information by tricking a human in a conversation or by sending an email instead of using sophisticated scanning and enumeration tools.

GLS FCAIT MCA

Footprinting Countermeasures

- The following are some of the most common countermeasures to protect your organizations and employees from malicious footprinting.

1. Provide user education to stay safe online. In the past, many companies restricted employees from accessing social networking sites from their network. However, nowadays social networking sites are used as marketing tools and have become essential for business. This is why user education in some cases is better than completely blocking social networking sites.
2. Configure web servers to avoid information leakage.
3. Educate employees to use pseudonyms (false name) on blogs, groups, and forums.
4. Do not reveal critical information in press releases, annual reports, product catalogues, and so on.
5. As an ethical hacker, use footprinting techniques to discover and remove any sensitive information about your company and systems that is publicly available

GLS FCAIT MCA

Footprinting Countermeasures

6. Prevent search engines from caching your websites and use anonymous registration services.
7. Enforce security policies to regulate the information that your users can reveal to third parties.
8. Configure separate internal and external DNS, or use split DNS and restrict zone transfer to authorized servers.
9. Disable directory listings in the web servers.
10. Educate users about social engineering risks.
11. Subscribe to use domain registration privacy services on the Whois Lookup database.
12. Prevent domain-level cross-linking for the critical assets.

GLS FCAIT MCA

Scanning

- The different network scanning concepts and scanning tools with different techniques for host discovery, port and service discovery, operating system (OS) discovery (banner grabbing/OS fingerprinting), and scanning beyond the intrusion detection system (IDS) and firewall.
- Host Discovery:- Attackers will want to know whether machines are alive before they attempt to attack. One of the most basic methods of identifying active machines is to perform a ping sweep. Just because ping can be blocked does not mean it is. Type in cmd ping www.google.com
- Although many organizations have restricted ping, you should still check to see if it is available. Ping uses ICMP and works by sending an echo request to a system and waiting for the target to send an echo reply back.
- If the target device is unreachable, a request timeout is returned. Ping is a useful tool to identify active machines and to measure the speed at which packets are moved from one host to another or to get details like the TTL.
- Linux system using the Wireshark packet capture (sniffer) tool

Scanning

- Programs that will perform ping sweeps include the following:
- Angry IP Scanner: https://angryip.org
- MASSCAN: https://github.com/robertdavidgraham/masscan
- Hping3: https://tools.kali.org/informationgathering/hping3/
- WS_Ping ProPack: https://ws-pingpropack.en.softonic.com/
- Nmap: https://nmap.org/

GLS FCAIT MCA

Port and Service Discovery

- Port scanning is the process of connecting to TCP and UDP ports for the purpose of finding what services and applications are running on the target device.
- After discovering running applications, open ports, and services, a hacker can then determine the best way to attack the system.
- There are a total of 65,535 TCP and UDP ports.
- These port numbers are used to identify a specific process that a message is coming from or going to.

- You can find a list of well-known ports at http://www.iana.org/assignments/portnumbers.
- https://en.wikipedia.org/wiki/List_of_TCP_and_UDP_port_numbers

GLS FCAIT MCA

Port and Service Discovery

- TCP offers robust communication and is considered a connection protocol. TCP establishes a connection by using what is called a three-way handshake. Those three steps proceed as follows:

1. The client sends the server a TCP packet with the sequence number flag (SYN flag) set and an initial sequence number (ISN).

2. The server replies by sending a packet with the SYN/ACK flag set to the client. The synchronize sequence number flag informs the client that it would like to communicate with it, and the acknowledgment flag informs the client that it received its initial packet. The acknowledgment number will be one digit higher than the client's ISN. The server generates an ISN, as well, to keep track of every byte sent to the client.

3. When the client receives the server's packet, it creates an ACK packet to acknowledge that the data has been received from the server. At this point, communication can begin.

GLS FCAIT MCA

Nmap

- Nmap was developed by a hacker named Fyodor Yarochkin.
- It is probably the most widely used port scanner ever developed. It can do many types of scans and OS identification. It also enables you to control the speed of the scan from slow to insane.
- Nmap can be installed as a GUI or command-line program in Linux, Windows, and macOS; and it is installed by default in Linux distributions such as Kali Linux, Parrot Security OS, BlackArch, Pentoo, and others.
- You can download Nmap from https://nmap.org.
- The Nmap Scripting Engine (NSE) is one of Nmap's most powerful and flexible features. It allows users to create and use simple scripts to automate a wide variety of networking tasks.

GLS FCAIT MCA

Hping

- Hping is another very useful ethical hacking tool that can perform both ping sweeps and port scans.
- Hping works on Windows and Linux computers and can function as a packet builder.
- You can find the Hping tool at http://www.hping.org or download the Linux Backtrack distribution, which also contains Hping. Hping2 and 3 can be used for firewall testing, identifying honeypots, and port scanning.

GLS FCAIT MCA

OS Fingerprinting (banner grabbing)

- At this point in the information-gathering process, the hacker has made some real headway (improvement). IP addresses, active systems, and open ports have been identified.
- Although the hacker might not yet know the types of systems he is dealing with, he is getting close.
- Fingerprinting is the primary way to identify a specific system.
- The hacker perform active fingerprinting, which basically sends malformed packets to the target in the hope of eliciting (provoking) a response that will identify it.
- Although active fingerprinting is more accurate, it is not as stealthy (silent) as passive fingerprinting.
- Passive fingerprinting is really sniffing, because the hacker is sniffing packets as they come by. These packets are examined for certain characteristics that can be pointed out to determine the OS.
- The following four commonly examined items are used to fingerprint the OS:

GLS FCAIT MCA

OS Fingerprinting

- The following four commonly examined items are used to fingerprint the OS:

1. IP TTL value: Different operating systems set the TTL to unique values on outbound packets.
2. TCP window size: OS vendors use different values for the initial window size.
3. IP DF option: Not all OS vendors handle fragmentation in the same way. A common size with Ethernet is 1500 bytes.
4. IP Type of Service (TOS) option: TOS is a 3-bit field that controls the priority of specific packets. Again, not all vendors implement this option in the same way.

GLS FCAIT MCA

Finding Open Services

- Most scanning programs, such as Nmap and SuperScan, report what common services are associated with those open ports. This easiest way to determine what services are associated with the open ports that were discovered is by banner grabbing.
- OS Fingerprinting (banner grabbing) takes nothing more than the Telnet and FTP client built in to the Windows and Linux platforms.
- OS Fingerprinting provides important information about what type and version of software is running.
- Many servers can be exploited with just a few simple steps if the web server is not properly patched.
- Telnet is an easy way to do this OS Fingerprinting for FTP, SMTP, HTTP, and others.
- The command issued to banner grab with the Linux curl command would contain the following syntax: curl IP_Address port as demonstrated

GLS FCAIT MCA

GLS UNIVERSITY
Promoted By Gujarat Law Society Since 1927

THANK YOU

GLS FCAIT MCA